PRODUCT OVERVIEW / INTERNAL AUDIT

Issue Triage Assistant

Product, workflow, architecture and demo guide

V2 concept build | November 2026 | Synthetic examples only

Executive summary

The assistant helps auditors find relevant precedent, controls, and policy, then prepares a cited issue suggestion or RAU scoping pack for human review. An explicit LangGraph workflow tracks state, performs retrieval and citation checks, recovers from bounded validation errors, and pauses for human decisions. The auditor owns severity and disposition.

After a durable approve/edit action and passing pre-approval checks, fixed MCP workflow nodes can create a Jira draft and notify the configured business owner. The persisted final edited suggestion supplies both payloads. No external write happens before approval; Jira has no close, transition, or final-assignment tool.

Project item	Current concept build
Purpose	Cited decision support for single issues and RAU testing scope.
Data boundary	Generated synthetic clients, past issues, Word control documents, and PDF policy documents only.
Search	Pinecone semantic retrieval + local BM25 keyword retrieval, fused by Reciprocal Rank Fusion.
Workflow	Streamlit + LangChain structured output + explicit LangGraph workflows with human checkpoints.
Persistence	SQLite locally; Postgres scaffold for hosted learning. Run, source, decision, document, and tool-call trail.
Human authority	Auditor approves, edits, rejects, and decides each scope cluster; no evidence-sufficiency judgement.

Operating principle The assistant drafts and cites. The auditor decides.

Product behavior and workflow

Single-issue triage

1. Auditor enters title, description, synthetic client, audit, required RAU and tested attributes; audit context and control hint are optional.
2. Graph retrieves exact-audit duplicate candidates separately from same-client cross-audit precedent, plus relevant controls and policies.
3. Typed model output proposes severity, root cause, control, duplicate status, similar issues, remediation, confidence, and citations.
4. Validator checks citation membership, source identity/type where required, and exact quotes. One bounded repair may run. If retrieval or citation validation remains weak, the auditor sees a plain-language retry message and collapsed technical details; no unsupported suggestion reaches approval. An invalid duplicate-warning label is downgraded to uncited Insufficient evidence rather than treated as a duplicate.
5. Passing suggestions pause for an auditor approve/edit/reject action. Edits are revalidated and durably saved before optional downstream calls.

RAU scoping

RAU is the primary search key. Client is required; audit, audit period, controls, RAU name, and attributes are optional refinements. A recognized year filters retrieval to matching synthetic audit IDs. The scoping graph clusters issues by control, attribute, and root cause and pauses for an auditor decision and reason on every cluster.

Run chat and summary documents

Chat is visible in both tabs and becomes active after the run retrieves sources. It answers only from that run's chunks, cites facts, supports follow-up questions, and cannot change suggestions or decisions. Redacted MCP call history is available per triage and scoping run, including approved issue history after the review panel closes. In RAU scoping, the summary-draft expander stays visible and explains that all cluster decisions and retrieved past-issue sources are required. The draft page shows metadata and PDF controls rather than repeating the full document body; auditors open or download the cited PDF to review its content. The separate edit decision still presents editable fields. A requested draft has its own human review checkpoint and is never auto-published or shared.

Stateful workflow pattern

Intake	Retrieve	Draft	Validate	Human checkpoint	Continue or stop
Issue / RAU context	Hybrid search + filters	Typed cited output	C01-C05 / source checks	Approve, edit, reject, or cluster decision	Persist; then authorized fixed tools only

Human approval and pre-approval checks

The approve/edit action is unavailable until every check passes, an applicable warning is acknowledged, or the permitted C03 lead override is recorded. A non-overridable failure blocks approval. Email verification checks configuration and address readiness only; it does not send a message.

ID	Check	Pass condition	Override
C01	Citation completeness	Every supported severity, root cause, control, and remediation claim has a citation; insufficient-evidence fields stay uncited.	No
C02	Citation validity	Each citation resolves to a chunk retrieved in this run; quotes match exactly.	No
C03	Control/version	Control exists, is in RAU scope, and version matches live V2 or indexed V1 with version note.	Allowlisted lead only, reason required; mark superseded
C04	RAU scope	Client, audit, RAU, and attributes match; no cross-client or cross-RAU items.	No
C05	Duplicate check	Local check for same RAU + control + root cause + open status. Exact open duplicate blocks.	No
EV1	Email readiness	Configured destination and backend are valid and ready, without sending.	No write

Citation and recommendation limits

- Every supported field cites a source ID, chunk ID, and verbatim quote from current-run retrieval.
- Exact quote presence does not establish semantic support; the auditor judges whether the source supports the claim.
- Semantic/BM25/RRF diagnostics are rank signals, not probability or confidence values.
- Insufficient retrieval is a retrieval limitation, not evidence sufficiency assessment.
- Cross-audit precedent is not an exact-audit duplicate. C05 stays local and does not call Jira.

Human decisions are durable

Approval/edit/rejection records the reviewer and reason where required. If approval passes, the graph stores the final edited suggestion, then may run Jira draft creation and owner notification in fixed order. A rejected or unsupported suggestion cannot reach the Jira write node.

System architecture and governed tools

Component	Role
Streamlit	Synthetic issue intake, RAU scoping, citations, run-scoped chat, review decisions, collapsible histories.
LangChain	Prompt construction, structured model output, embedding and vector-store integration.
LangGraph	Named steps, explicit state, retrieval/citation recovery, durable human interrupts, fixed post-approval calls.
Pinecone + BM25	Semantic vectors plus lexical search over local synthetic corpus; RRF combines rankings after filters.
SQLAlchemy	SQLite/Postgres persistence for runs, sources, approvals, scope decisions, documents, and audit events.
MCP servers	Governed Jira draft, owner email, and cited summary-document tools. Controls/policies use Pinecone and BM25; live Controls/Evidence MCP servers are not implemented.
Optional Mem0	Auditor/client scoped approved patterns only; never raw issue text or evidence.

MCP permissions and order

Server	Allowed capability	Boundary
Jira	Create a labeled issue draft from a persisted approved suggestion.	No close, transition, or final assignment; the server rechecks approval and citations.
Email	Notify configured business-owner address.	Only after the approved Jira draft exists; recipient is not model-selected.
RAG retrieval	Retrieve indexed controls and policies with Pinecone + BM25.	Separate live Controls/Evidence MCP servers are not implemented in this branch; raw evidence is not downloaded or judged.
Documents	Create a cited summary draft.	Fixed workflow, validated in-run sources; no publish/share/send.

Auditability and recovery

Every implemented tool call records run, server/tool name, redacted arguments, result status, duration, and approver context for writes. Auditors can inspect those calls in the matching triage or RAU-scoping run and in the global audit view. Secrets remain in environment or deployment secret storage. Timeouts, bounded transient retries, structured errors, and visible failure status keep the workflow inspectable when Jira, email, or document MCP services are unavailable. Local approval is not undone by Jira or email failure; RAG retrieval is independent of those services.

Outbound issue presentation

Jira and email format the persisted final approved or edited issue into sections for issue details, assessment, remediation, review context, and source citations. The formatter does not change the accepted content. Jira links the run and approval IDs; email includes the Jira link and configured owner notification.

Synthetic demo inputs

Single issue: access recertification

Field	Enter
Title	Quarterly access recertification was still incomplete at cutoff
Description	At the review cutoff, several sampled application accounts had no completed quarterly recertification sign-off. Continued business need could not be confirmed for those accounts. Scope is limited to the synthetic-client-a identity and access sample.
Synthetic client / audit	synthetic-client-a / synthetic-audit-iam-2026
Audit context / control hint	FY2026 identity and access review / AC-04
RAU / attributes	RAU-AC-01 / completeness

This paraphrases generated access-attestation precedent to demonstrate semantic retrieval. Inspect the exact-audit duplicate set and cross-audit precedent separately; inspect source quotes before human approval.

RAU scoping

Field	Enter
Synthetic client	synthetic-client-a
RAU ID / name	RAU-AC-01 / Application access recertification
Audit context / period	synthetic-audit-iam-2026 / 2026
Controls / attributes	AC-02, AC-04, AC-07 / authorization, completeness, timeliness

Chat follow-ups

- List the audits represented in the retrieved issues.
- List the policy documents retrieved and what each one covers.
- What remediation approach worked for the previous access attestation issue?
- Which source supports the AC-04 mapping? Quote it.
- Which of those audit records is from 2025?

Decision and document examples

Edit reason: “Synthetic demo: clarify the look-back scope before approval.” Rejection reason: “Synthetic demo: request additional control-owner confirmation.” Cluster decision reason: “Retain for testing: periodic sign-off and escalation are relevant to this RAU.” Summary title: “Synthetic RAU access review summary.”

Four to five minute demo outline and operating setup

Time	Show and say
0:00-0:35	Business problem: differently worded issues fragment precedent; auditors need consistency and a checkable source trail.
0:35-1:25	Enter the synthetic access issue. Show semantic + keyword retrieval, RRF ranking, and one source citation.
1:25-2:15	Show citation-aware recovery and C01-C05/EV1. Demonstrate an edit with reason or a separate rejection run; explain that failed gates block approval.
2:15-3:10	Build RAU-AC-01 scope for 2026 with AC-02/04/07; show citations and MCP history, record cluster reasons, create a summary draft, then open its PDF.
3:10-3:45	Ask a run-scoped chat question, inspect its citation, and explain that chat cannot change the suggestion or record a decision.
3:45-4:30	Show post-approval Jira/email sequencing, final edited content, and per-run/global MCP audit history. Mailpit can capture local email.
4:30-5:00	Close with the human decision boundary and real-client deployment gates.

Local run sequence

1. Create/activate the project environment, install requirements, and copy `.env.example` to `.env`.
2. Configure the OpenAI and Pinecone keys plus compatible index name/model/dimension. Keep secrets private.
3. Run `python scripts/generate_synthetic_data.py` and `python -m src.issue_triage.ingestion.cli_ingest`.
4. For local email capture, start `docker compose -f docker-compose.mailpit.yml up -d`; inspect at `http://localhost:8025`.
5. For an end-to-end Jira demo, configure a non-production Jira sandbox and the authorized synthetic demo reviewer. Start with `streamlit run app.py`.

Real-client readiness

This concept build is not ready for real client information. Before deployment with real data, implement and verify identity-to-client/audit authorization on every read/write path; complete privacy, security, retention, vendor, backup, and incident reviews; use deployment-managed secrets; resolve and lock dependencies; validate migrations/recovery; and independently evaluate retrieval, severity calibration, prompts, and citation relevance.

Companion material docs/product_spec.md | docs/demo_scenarios.md | docs/demo_script_4min.md | docs/system_prompt.md | SKILLS.md